

Beyond the MDR Threshold:

Closing the Credential Attack Detection Gap for Small Healthcare
Organizations Underserved by Signature-Based MDR Alerting

Task 3: Technology-Supported Security Solution
D490: Cybersecurity Graduate Capstone
Western Governors University
Adam Cote
April 2026

Table of Contents

Rubric Section	Section Title	Page
A	Policies Adopted	3
A1	How the Solution Improves Cybersecurity Decision-Making	4
B	Cybersecurity Assurance Criteria	6
C	Data Collection and Implementation Elements	8
D	Investigation and Mitigation	10
E	Cybersecurity Plans, Standards, or Procedures	12
E1	Regulatory and Framework Alignment	13
E2	Applications, Tools, Installation Guides, and User Guides	14
F	Post-Implementation Environment	16
F1	Security Posture and Efficiency	16
F2	New Data Analysis	18
F3	Summative Evaluation	19
F4	Post-Implementation Risks	21
F5	Meeting Stakeholder Needs	22
G	Post-Implementation Maintenance Plan	25
H	Original Artifact	27
I	Sources	28

A. Policies Adopted

What happens when a small healthcare organization discovers that credential attacks have been hammering its domain controller for six months, and neither its internal staff nor its managed detection and response provider raised a single alert? What does it mean for the protection of your patients' health records when the entire security monitoring function depends on an external vendor whose detection thresholds were never calibrated for the environment being defended? The RCHS cybersecurity remediation project produced two formal policy documents that address the governance and procedural gaps exposed by this scenario, as evidenced by the February 2026 credential spray and brute-force incident. These documents, the RCHS Log Review and Incident Detection Policy and the VPN Secure Setup Runbook, transform the technical controls implemented during the four-phase project into sustained organizational standards with defined accountability, review schedules, and regulatory alignment. Before this project, no formal policy governing centralized log review, incident-detection thresholds, or VPN authentication security existed within the organization; security monitoring relied entirely on the managed detection and response provider, and VPN configuration was undocumented and maintained through the institutional knowledge of a single administrator.

The RCHS Log Review and Incident Detection Policy, designated RCHS-IS-004, is the primary policy output and represents an entirely new governance artifact created to close the audit control gap that enabled the February 2026 attack to persist undetected for approximately six months, a duration roughly equivalent to two full academic terms, during which hundreds of authentication failures accumulated daily without a single internal review. The policy designates Marcus Hale, IT Systems Administrator, as the policy owner, with the Executive Director and the Compliance Officer as co-signatories. Its regulatory basis draws from HIPAA Security Rule §164.312(b), which requires audit controls capable of recording and examining activity in systems containing electronic protected health information; NIST SP 800-53 Rev. 5 controls AU-2, AU-3, AU-6, AU-9, AU-11, and SI-4; and CIS Controls v8 Control 8 (U.S. Department of Health and Human Services, 2003; National Institute of Standards and Technology, 2020; Center for Internet Security, 2021). The policy scope encompasses all Windows systems generating security events within the RCHS environment, specifically the RCHSDC domain controller, the SonicWall gateway, the WEC collector, and the Distributed File System Replication (DFSR) file servers hosting electronic protected health information.

RCHS-IS-004 establishes a tiered review schedule consisting of a weekly review of critical authentication event volume, a monthly review of PHI file access patterns across all monitored event categories, a quarterly assessment of overall policy effectiveness and MDR SLA compliance, and annual re-authorization requiring executive and compliance officer approval. The policy defines eight anomaly thresholds with corresponding Level 1 and Level 2 escalation paths, ensuring that detected anomalies trigger a defined investigative and reporting response rather than relying on ad hoc judgment. Log retention is set at 6 years to comply with HIPAA documentation requirements under 45 C.F.R. § 164.316(b)(2). The full text of RCHS-IS-004 appears in Appendix H of the supporting documentation.

The VPN Secure Setup Runbook, documented in Appendix G, serves as both the implementation record for the five-gate VPN security configuration completed during Phase 1 and the ongoing operational procedure for VPN user lifecycle management. The runbook formalizes the configuration of IP allowlisting through the Secure Sockets Layer Virtual Private

Network (SSLVPN) IP Allowlist address group, per-user Time-based One-Time Password (TOTP) enrollment via NetExtender QR code, Active Directory security group management through the RCHS-VPN-Users group, TOTP multi-factor authentication enforcement on the SSLVPN Services group, and LDAPS migration from port 389 to port 636 as a repeatable, documented standard. It includes numbered procedural steps for each gate, PASS/FAIL test result tables documenting the outcome of each validation, and cross-references to the Wireshark validation results confirming the LDAPS migration. The runbook defines ongoing procedures for new VPN user enrollment, IP allowlist updates upon Wide Area Network (WAN) IP changes, and access restoration following TOTP re-enrollment, ensuring that VPN security management does not depend on the institutional knowledge of any single administrator. Taken together, these two policy artifacts establish the governance foundation upon which the organization's security posture will be sustained, evaluated, and refined as threat conditions and regulatory expectations continue to evolve.

A1. How the Solution Improves Cybersecurity Decision-Making

The February 2026 incident revealed that cybersecurity decision-making at RCHS was reactive, data-poor, and structurally dependent on an external provider whose detection thresholds were not calibrated for the organization's authentication baseline. The attack generated authentication failure volumes approximately 140 to 160 times above the organization's documented baseline, the security equivalent of a fire alarm sounding continuously for months in a building where no one had been assigned to listen for it, yet this information was invisible to internal staff because no centralized event data existed, and no routine review process was in place to surface anomalies. Decision-making occurred only in a crisis, when Marcus Hale manually discovered the attack using Wireshark packet capture on the domain controller; prior to that discovery, no internal data source or analytical process had indicated that a security event was underway despite six months of sustained attack activity.

The implemented solution addresses each of these deficiencies through complementary technical and procedural controls. Centralized event data via the WEF/WEC infrastructure ensures that security-relevant events from the main controllers and file servers are visible in a single location on demand, eliminating the need for specialized packet-capture tools to obtain forensic data. The automated spray detection script queries the Windows Event Log against two defined thresholds: eleven or more consecutive failures on a single account and five or more distinct accounts failing within a one-hour window, converting raw event volume into actionable alerts without requiring prior analyst interpretation of log entries. Both thresholds were validated during the April 11, 2026, controlled simulation, confirming that the detection capability functions as designed against real authentication event data forwarded through the WEF/WEC pipeline (see Appendix K).

The formal review cadence established by RCHS-IS-004 converts the ad hoc observation that characterized pre-incident security monitoring into a scheduled, documented process with defined accountability and escalation paths. Security posture is assessed on a regular cycle rather than being crisis-triggered, and each review iteration produces a documented record that supports ongoing compliance requirements and forensic readiness for future incidents. Furthermore, the documented procedures in Appendix G and RCHS-IS-004 eliminate the single-administrator knowledge concentration that constrained the initial incident response; any qualified IT staff member can execute VPN user lifecycle management or conduct a log review by following the written procedural steps, reducing organizational dependence on individual expertise and

ensuring continuity of the security function across staffing changes. The trajectory established by these controls positions RCHS to approach future security decisions from a foundation of structured evidence rather than crisis-driven improvisation, a shift whose long-term value is likely to compound as the threat landscape facing small healthcare organizations continues to intensify.

B. Cybersecurity Assurance Criteria

The implemented solution satisfies three cybersecurity assurance criteria established by the rubric: promotion of automation, improvement and modernization of security infrastructure, and implementation of industry-standard tools and infrastructure. These criteria are addressed through integrated technical and procedural controls rather than isolated features, and each criterion maps to specific project deliverables validated through the Phase 4 summative evaluation.

Automation is achieved through two primary mechanisms: eliminating manual data collection and introducing threshold-based alerting. The WEF/WEC subscription-based event forwarding system, configured as the RCHS-SecurityEvents subscription in collector-initiated mode, automatically centralizes security events from all enrolled forwarders to the WEC collector without manual collection effort; as of the April 11, 2026, testing period, the Forwarded Events log had accumulated 2,571 events from the domain controller alone, as confirmed by Screenshot [09] (see Appendix O, Phase 2 Screenshots). The PowerShell spray detection script provides a second automation layer by querying the Windows Event Log against the two defined detection thresholds and surfacing threshold crossings as explicit alerts. Both thresholds fired during the April 11 controlled simulation as documented in Screenshot [23], demonstrating that the automated detection capability produces actionable output from the centralized event data without requiring the operator to manually interpret raw log entries.

The project accomplishes three specific technical modernizations that collectively transform the organization's security posture from a pre-incident state of structural vulnerability to a post-implementation state of documented, validated control. The migration from cleartext LDAP on port 389 to LDAPS on port 636 eliminates the confirmed credential exposure that Wireshark packet capture documented during the February 2026 incident investigation; post-migration validation on April 6, 2026 confirmed zero packets on port 389 and an active TLS 1.2/1.3 handshake on port 636, as documented in the Wireshark capture screenshots (see Appendix O, Phase 3 Screenshots). Enforcing TOTP-based multi-factor authentication on the SSL VPN portal ensures that stolen or guessed credentials alone cannot authenticate to the network, closing the single-factor vulnerability that would have granted an attacker silent, undetected access during the six-month attack window. The deployment of WEF/WEC centralized logging represents a category change rather than an incremental change. Prior to this project, no centralized log collection infrastructure existed within the RCHS environment, meaning the organization possessed no technical mechanism for meeting the HIPAA audit control requirement under §164.312(b) (U.S. Department of Health and Human Services, 2003).

The solution is built entirely on industry-standard tools and infrastructure, rather than on proprietary or custom platforms that require specialized licensing or vendor dependency. SonicWall SSL VPN with TOTP is an industry-standard remote access solution with native multi-factor authentication. Windows Event Forwarding and the Windows Event Collector are native Windows Server audit infrastructure components directly aligned with NIST SP 800-53 Rev. 5 AU controls for event logging and audit record management (National Institute of Standards and Technology, 2020). LDAPS is the industry-standard encrypted directory authentication protocol, and Wireshark is the industry-standard protocol analysis tool used for validation of the LDAPS migration. Active Directory security groups provide access control via the RCHS-VPN-Users group, and PowerShell serves as the scripting platform for both spray detection and test account lifecycle management during the controlled simulation. The governing

compliance and control frameworks, NIST SP 800-53 Rev. 5, CIS Controls v8, and the HIPAA Security Rule, are themselves industry-standard references that ensure the solution's design and validation criteria are externally auditable, reproducible, and aligned with recognized best practices (Center for Internet Security, 2021). This deliberate reliance on native, standards-aligned tooling positions the organization to adopt future enhancements, such as Security Information and Event Management (SIEM) integration or expanded endpoint telemetry, without requiring a foundational platform migration.

C. Data Collection and Implementation Elements

The implemented security architecture establishes a comprehensive digital evidence collection capability that did not exist within the RCHS environment before this project. The WEF/WEC infrastructure serves as the primary evidence-collection system, centralizing security-relevant events from the domain controller to a dedicated WEC collector virtual machine via the RCHS-SecurityEvents subscription. Two categories of digital evidence are collected: authentication events that enable credential attack detection and forensic reconstruction, and PHI file access events that enable HIPAA-compliant audit monitoring of electronic protected health information.

Authentication events constitute the first major evidence category and include Event IDs 4624 (successful logon), 4625 (failed logon), 4740 (account lockout), 4648 (explicit credential logon), and 4776 (credential validation). These events collectively provide a complete record of who authenticated to the domain, when the authentication occurred, from which source system, and with what result. This dataset is forensically essential for any future investigation involving credential spray, brute-force attacks, or unauthorized access, as it enables the full reconstruction of authentication sequences without the labor-intensive Wireshark packet-capture methodology required to investigate the February 2026 incident. The accumulation of 2,571 events in the Forwarded Events log during the Phase 2 testing period, as confirmed by Screenshot [09], demonstrates that the pipeline is actively collecting and centralizing these events from the domain controller (see Appendix O, Phase 2 Screenshots).

The second evidence category addresses PHI file access events through Event IDs 4656 (handle request), 4660 (object deletion), 4663 (object access), and 5145 (network share access). System Access Control Lists trigger these events on PHI-bearing file shares on the DFSR file servers, as documented in Screenshot [10], which shows the System Access Control Lists (SACL) configuration for the C:\PHI_TestShare directory with Type set to All, Principal set to Everyone, Access set to Full control, and Applies to All. Each event record captures the account name, object name, access type, and timestamp, constituting the minimum dataset required for HIPAA breach investigation under §164.312(b) (U.S. Department of Health and Human Services, 2003). The formative pipeline test confirmed that Event ID 4663 arrived in the Forwarded Events log at 4:00:16 PM, sixteen seconds after the initiating file operation, as documented in Screenshot [11]; this latency is well within the five-minute KPI threshold established in the Task 2 summative evaluation plan (see Appendix O, Phase 2 Screenshots).

All events are forwarded to the centralized WEC collector, creating a single forensic repository that is independent of the availability of individual endpoint systems. Before this project, no such repository existed; the February 2026 attack could only be partially reconstructed from a single 4.15-hour Wireshark capture window on the domain controller, which documented 342 authentication attempts across 16 user accounts using 271 unique passwords. The centralized collection model ensures that future investigations draw on a complete, continuously maintained event archive rather than ad hoc forensic captures performed under crisis conditions.

The deployed control set addresses all three components of the confidentiality, integrity, and availability triad as they apply to the RCHS environment. Confidentiality is strengthened through four complementary controls: the LDAPS migration encrypts VPN authentication credentials in transit between the SonicWall appliance and the domain controller, directly remediating the cleartext LDAP exposure confirmed during the February 2026 investigation;

TOTP multi-factor authentication ensures that compromised credentials alone are insufficient to authenticate to the SSL VPN portal; the IP allowlist implemented through the SSLVPN IP Allowlist address group restricts VPN access initiation to pre-registered staff WAN addresses, reducing the external attack surface; and the SACL configuration on PHI file shares creates access visibility without restricting clinical file access, providing a detection-without-disruption model that preserves care delivery workflows while enabling file-level audit.

Integrity is addressed through the centralized audit architecture and the formal retention framework. The LDAPS migration prevents credential interception and manipulation in transit by encrypting the authentication exchange between the SonicWall gateway and the domain controller. Centralized audit logs stored on the WEC collector cannot be modified by the systems being audited; a log source failure on the domain controller does not compromise the existing records collected on the collector, preserving the integrity of the forensic archive independent of the source system's availability. RCHS-IS-004 establishes a six-year log retention schedule that supports long-term integrity for both compliance and investigative purposes, ensuring that audit records remain available for the duration required by HIPAA documentation standards under 45 C.F.R. §164.316(b)(2).

Availability considerations are addressed through the solution's resource-efficient design and its documented operational procedures. The WEC collector virtual machine was provisioned on existing Hyper-V infrastructure using the Endpoint-Base-Win11Pro configuration, with 3,100 megabytes of RAM allocated and an existing Windows Server license, requiring no additional hardware procurement and minimizing budget risk to ongoing operations. MFA deployment included per-user enrollment training delivered on April 7, 2026, through RCHS-TRAIN-002, with VPN access restored only after each of the ten RCHS-VPN-Users members confirmed TOTP enrollment, ensuring that no user experienced an unplanned access disruption without completing the enrollment process. The IP allowlist operational procedure documented in Appendix G defines the workflow for handling WAN IP changes, new user enrollment, and departed staff removal, ensuring that VPN user lifecycle management does not create availability bottlenecks due to undocumented or ad hoc administration. The cumulative effect of these measures is a security architecture that strengthens the confidentiality, integrity, and availability of the RCHS environment without imposing operational burdens that would be unsustainable for an organization of this size, establishing a model that can scale incrementally as organizational resources and threat conditions warrant.

D. Investigation and Mitigation

The remediation effort addresses both the investigation of the February 2026 credential spray incident and the ongoing mitigation of the systemic vulnerabilities it exposed. The investigation and mitigation elements span the full project lifecycle, from initial incident containment through the controlled validation of deployed detection controls, and the implemented capabilities ensure that future incidents can be investigated and mitigated through structured, documented processes rather than the ad hoc methods that characterized the initial response.

The February 2026 incident was investigated using Wireshark packet captures on the domain controller, a labor-intensive, non-scalable method that was nonetheless effective in establishing the attack parameters. The primary forensic product of this investigation was the documentation of 342 authentication attempts across 16 user accounts during a single 4.15-hour capture window, using 271 unique passwords, at a rate of approximately one attempt every 44 seconds sustained throughout the observation period. Event ID 4625 (failed logon) and Event ID 4740 (account lockout) volume spiked approximately 140 to 160 times above the organization's documented baseline during the active attack phase. Wireshark capture confirmed that authentication credentials were transmitted in cleartext in LDAP bind requests on port 389, directly validating the LDAPS migration requirement. The managed detection and response provider, Desert Cat, an organization with an inherent interest in demonstrating that its platform performed adequately during the incident period, provided a log export under ticket DC #48821193 confirming Event ID 4624 (successful logon) for two accounts during the attack window: RCHS_Architect, the SonicWall LDAP service account, and rtorres, a staff VPN user account (Desert Cat, 2026). Post-incident forensic review found no evidence of lateral movement or unauthorized data access from either account.

The implemented solution transforms the organization's investigative capability from ad hoc forensic reconstruction to structured, continuous evidence collection. The Forwarded Events log on the WEC collector provides a pre-populated forensic repository, enabling the reconstruction of authentication events for any future incident without deploying Wireshark. The spray detection script surfaces attack patterns in near-real time by querying centralized event data against defined thresholds, rather than requiring post-hoc manual analysis of packet captures or individual system logs. SACL-triggered events on PHI file shares enable file-level access reconstruction for any future incident involving electronic protected health information, a capability that did not exist during the February 2026 attack window and that directly supports the breach investigation requirements of the HIPAA Security Rule.

Mitigation proceeded through four phases following the Agile-informed phased delivery methodology established in Task 2. Phase 1 addressed immediate containment, beginning on February 27, 2026, when LDAP was disabled on the primary attack-surface device at IP address 72.91.34.152 per Desert Cat's recommendation. Password resets were executed for both confirmed Event ID 4624 accounts, RCHS_Architect and rtorres; active sessions were revoked; and both accounts were flagged for elevated monitoring. Subsequently, Phase 2 implemented the VPN hardening configuration in April 2026, deploying all five security gates as documented in Appendix G: IP allowlisting through the SSLVPN IP Allowlist address group, per-user TOTP enrollment via NetExtender QR code for all ten RCHS-VPN-Users members, Active Directory security group enforcement, TOTP multi-factor authentication enforcement on the SSLVPN Services group, and LDAPS migration to port 636. All nine previously WAN-accessible

SonicWall management portals at IP addresses 72.91.34.152, 72.91.34.71, 74.62.88.201, 67.184.93.215, 25.114.142.8, 25.114.198.4, 74.29.31.53, 74.29.33.18, and 74.62.88.51 were confirmed closed from an external cellular connection on April 10, 2026, each returning ERR_CONNECTION_TIMED_OUT as documented in Screenshots [04a] through [04i] (see Appendix O).

Concurrently, Phase 3 established the detection infrastructure and policy framework during April 2026. The WEF/WEC infrastructure was deployed and validated, with the RCHS-SecurityEvents subscription confirmed Active and forwarding events from the domain controller to the WEC collector. RCHS-IS-004 was written to govern the ongoing log review and incident-detection functions. All-staff security awareness training (RCHS-TRAIN-001) was delivered on April 7, 2026, to approximately 80 staff members, and supplemental VPN MFA training (RCHS-TRAIN-002) was delivered to 10 VPN users on the same date, as documented in Appendix M. The formal MDR SLA review was completed on March 18, 2026, with Desert Cat Concierge Manager Ethan Calloway, during which the critical user list was corrected. The detection threshold limitation was confirmed as a platform-level constraint with per-customer tuning committed to the product roadmap. However, it remains to be seen whether this commitment will materialize within a timeframe that meaningfully reduces organizational risk (see Appendix N). LDAPS was confirmed active via Wireshark validation on April 6, 2026, with zero packets observed on port 389 and TLS 1.2/1.3 handshake confirmed on port 636. Phase 4 executed the controlled spray simulation on April 11, 2026, under written management authorization (see Appendix L), using five non-production test accounts designated spray_test01 through spray_test05, created at 16:12:54 and disabled at 17:01:04 on the same day. Both detection thresholds fired: the account threshold was exceeded when spray_test01 accumulated 26 failures against the 11-consecutive-failure threshold, and the spray pattern threshold was exceeded when all five distinct accounts recorded failures within the one-hour detection window, as documented in Screenshot [23] and the full summative evaluation record in Appendix K.

E. Cybersecurity Plans, Standards, or Procedures

The project developed four primary procedural outputs that collectively formalize the security controls, operational processes, and training requirements implemented during the remediation effort. Each output serves a distinct function within the post-implementation governance structure, and together they ensure that the technical controls deployed during the project are sustained through documented, repeatable procedures with defined accountability.

The RCHS Log Review and Incident Detection Policy (RCHS-IS-004, Appendix H) provides the governance foundation for the entire detection and audit infrastructure. Beyond the policy provisions described in Section A, RCHS-IS-004 includes an eight-step review procedure that guides the reviewer through each event category in the Forwarded Events log, defines what constitutes normal versus anomalous volume for each event type, and specifies the escalation action for each anomaly category. The policy defines eight anomaly thresholds with tiered escalation responses: for example, more than twenty Event ID 4625 events per hour from a single source IP triggers a Level 1 investigation by the policy owner, while five or more distinct accounts with authentication failures within a one-hour window triggers Level 2 escalation involving the Executive Director, the Compliance Officer, and formal notification to the MDR provider. Formal role assignments designate Marcus Hale, IT Systems Administrator, as the Policy Owner, with co-authorization by the Executive Director and the Compliance Officer, ensuring that the policy carries organizational authority beyond the IT function.

The VPN Secure Setup Runbook (Appendix G) provides the technical procedure for all five VPN security gates with numbered implementation steps, PASS/FAIL test result tables documenting the validation outcome for each gate, and cross-references to Wireshark validation results for the LDAPS migration. A notable feature of the runbook is the authentic documentation of a morning FAIL result for the LDAP bind filter test during the April 1, 2026, field session, which occurred before the configuration was corrected and retested to PASS. The inclusion of this failure strengthens the credibility of the subsequent PASS results by demonstrating that the testing process was capable of detecting a misconfiguration and that the final results reflect a corrected and validated state rather than an untested assumption.

The WEF/WEC Implementation Runbook (Appendix C, Task 2 documentation) covers the full deployment procedure for the centralized event collection infrastructure, including WEC collector virtual machine provisioning on existing Hyper-V infrastructure, RCHS-SecurityEvents subscription configuration in collector-initiated mode, Group Policy Object-based forwarder enrollment, SACL configuration on PHI-bearing file shares, and ongoing subscription health monitoring procedures. This document serves as both the implementation record for Phase 2 and the operational reference for ongoing WEC infrastructure management, ensuring that subscription maintenance and troubleshooting do not depend on undocumented knowledge.

The MFA training procedures documented under RCHS-TRAIN-001 and RCHS-TRAIN-002 (Appendix M) constitute procedural records that document both training delivery and access management processes. RCHS-TRAIN-001 records the all-staff security awareness training session delivered on April 7, 2026, to approximately 80 staff members, covering threat recognition, reporting procedures, and the organizational changes resulting from the remediation project. RCHS-TRAIN-002 documents the per-user VPN MFA supplemental training delivered on the same date to the ten VPN users and functions as both a training record and an access management procedure: the document requires each user to identify their WAN IP address for allowlisting, complete TOTP enrollment via QR code in NetExtender, and sign the

acknowledgment, with VPN access restored only upon completion of all three steps. This dual function makes RCHS-TRAIN-002 a particularly significant procedural output because it creates a per-user enrollment confirmation chain tied directly to access restoration, establishing a documented record that each VPN user's multi-factor authentication was confirmed operational before network access was restored. Collectively, these four procedural outputs ensure that the security controls implemented during the remediation project are not merely technical configurations but institutionally sustained practices with defined ownership, documented procedures, and repeatable validation criteria that will endure beyond the tenure of any individual administrator.

E1. Regulatory and Framework Alignment

The solution aligns with three regulatory and industry compliance frameworks, with the HIPAA Security Rule at 45 C.F.R. Part 164 serving as the primary regulatory driver. The project directly addresses six HIPAA Security Rule provisions that were either unmet or insufficiently implemented at the time of the February 2026 incident. Section §164.312(b) requires audit controls capable of recording and examining activity in information systems containing electronic protected health information; the WEF/WEC centralized event collection system, the SACL configuration on PHI file shares, and RCHS-IS-004 collectively satisfy this requirement by providing the technical infrastructure, the access monitoring capability, and the governance framework for ongoing compliance (U.S. Department of Health and Human Services, 2003). Section §164.312(d) requires person or entity authentication, which is addressed by the TOTP multi-factor authentication on the SSL VPN portal and the LDAPS-secured Active Directory authentication, as documented in Appendix G, Gates 4 and 5, respectively. Section §164.312(a)(1) requires access controls, implemented through the IP allowlist and the RCHS-VPN-Users Active Directory security group, which together create a two-layer VPN access control mechanism.

Section §164.312(e)(1) requires transmission security for electronic protected health information, directly addressed by the LDAPS migration from cleartext LDAP on port 389 to TLS-encrypted authentication on port 636; Wireshark validation on April 6, 2026, confirmed zero packets on port 389 and an active TLS 1.2/1.3 handshake on port 636. Section §164.308(a)(5) requires security awareness and training for all members of the workforce, satisfied by the all-staff training delivered on April 7, 2026 (RCHS-TRAIN-001) and the VPN MFA supplemental training delivered on the same date (RCHS-TRAIN-002), both documented in Appendix M. Section §164.316(b)(1) and (b)(2) require documentation of policies and procedures with a six-year retention period; RCHS-IS-004 establishes the documentation standard and the retention schedule, and training records are retained as components of the organizational audit trail.

NIST SP 800-53 Rev. 5 provides the secondary compliance framework, with five controls directly implemented by the solution (National Institute of Standards and Technology, 2020). Control AU-2 (Event Logging) is satisfied by the WEF/WEC subscription configured to collect all nine required event ID categories across authentication and file access domains. Control AU-3 (Content of Audit Records) is satisfied by the Forwarded Events records, which include timestamp, source system, event type, account name, and result, all fields required for meaningful audit record content. Control AU-6 (Audit Review, Analysis, and Reporting) is implemented through the RCHS-IS-004 review cadence and responsibility structure, defining weekly, monthly, quarterly, and annual review cycles, along with assigned accountability and

escalation procedures. Control AU-11 (Audit Record Retention) is addressed by the six-year minimum retention period established in RCHS-IS-004 Section 9. Control SI-4 (System Monitoring) is implemented by the spray detection script, which continuously monitors authentication event patterns against defined detection criteria validated in the April 11 simulation.

CIS Controls v8, specifically Control 8 (Audit Log Management), provides tertiary implementation guidance aligned with the solution's technical and procedural controls (Center for Internet Security, 2021). Safeguard 8.1 (Audit Log Management Process) is satisfied by RCHS-IS-004, which serves as the organizational audit log management process artifact with defined ownership, review cadence, and escalation procedures. Safeguard 8.2 (Collect Audit Logs) is satisfied by the WEF/WEC subscription, which collects audit logs from the domain controller and, through SACL configuration, from PHI file access events on DFSR file servers. Safeguard 8.11 (Conduct Audit Log Reviews) is satisfied by the weekly and monthly review cadence defined in RCHS-IS-004, converting audit log collection from a passive technical function into an active, reviewed security process with documented outcomes. The alignment across all three frameworks ensures that the organization's compliance posture is not dependent on a single regulatory interpretation, a consideration whose importance will likely increase as federal enforcement priorities and industry control expectations continue to evolve in the healthcare sector.

E2. Applications, Tools, Installation Guides, and User Guides

The technical implementation employs a combination of existing infrastructure components and newly deployed tools, all of which are industry-standard technologies requiring no proprietary licensing beyond existing organizational assets. The SonicWall SSL VPN appliance, already in place as the organization's remote access gateway, was reconfigured to enforce TOTP-based multi-factor authentication, IP allowlisting, and LDAPS-secured Active Directory authentication. Microsoft Active Directory was leveraged to create the RCHS-VPN-Users security group, which serves as the authoritative permitted-user list governing VPN access. Windows Event Forwarding and the Windows Event Collector represent the primary new infrastructure deployment, with the WEC collector virtual machine provisioned on existing Hyper-V infrastructure using the Endpoint-Base-Win11Pro configuration with 3,100 megabytes of allocated RAM and an existing Windows Server license, requiring no additional hardware cost. Additional tools include Microsoft Event Viewer for WEC management and event review, Wireshark for packet capture validation of the LDAPS migration on the domain controller, PowerShell for both the spray detection script and test account lifecycle management during the controlled simulation, NetExtender as the SonicWall VPN client supporting TOTP enrollment via QR code, and TOTP authenticator applications installed on each VPN user's device during enrollment.

The project produced four documentation artifacts that serve as installation guides, user guides, and operational references for ongoing system management. Appendix G, the VPN Secure Setup Runbook, functions as a full installation guide for the five-gate VPN security configuration, with numbered procedural steps, PASS/FAIL test result tables, and cross-references to Wireshark validation for each applicable gate. The WEF/WEC Implementation Runbook (Appendix C, Task 2 documentation) provides the installation guide for WEC collector provisioning, RCHS-SecurityEvents subscription setup, GPO-based forwarder enrollment, and SACL configuration on PHI-bearing file shares. RCHS-TRAIN-002 (Appendix

M) contains embedded per-user TOTP enrollment instructions, including procedures for identifying the user's WAN IP address and scanning the QR code in the NetExtender client, effectively functioning as a user guide for VPN users completing the multi-factor authentication enrollment process. RCHS-IS-004 (Appendix H) includes the defined eight-step review procedure, anomaly thresholds, escalation paths, and retention schedule, serving as the operational guide for the ongoing security review function supported by the WEF/WEC infrastructure. These documentation artifacts collectively ensure that the knowledge required to operate, maintain, and extend the deployed security infrastructure is institutionally preserved rather than dependent on the availability of the individuals who performed the initial implementation.

F. Post-Implementation Environment

The post-implementation environment at RCHS reflects the deployment of new infrastructure, the reconfiguration of existing systems, and the establishment of formal governance processes that collectively address the six systemic gaps identified during and after the February 2026 credential spray incident. The most significant infrastructure addition is the WEC collector virtual machine, provisioned on existing Hyper-V hardware in a dedicated security monitoring role that did not exist before the project. The RCHS-SecurityEvents subscription serves as the operational backbone of the new detection capability, automatically centralizing authentication and file-access events from the domain controller to the WEC collector via the Windows Event Forwarding protocol, without manual intervention or specialized collection tools.

The SonicWall SSL VPN infrastructure has been reconfigured with five security gates documented in Appendix G: IP allowlisting through the SSLVPN IP Allowlist address group, restricting VPN source addresses to pre-registered staff WAN IPs, per-user TOTP enrollment via NetExtender QR code for all ten RCHS-VPN-Users members, Active Directory security group enforcement through the RCHS-VPN-Users group, TOTP multi-factor authentication enforcement on the SSLVPN Services group, and LDAPS migration from cleartext LDAP on port 389 to TLS-encrypted authentication on port 636. These are configuration changes to existing infrastructure rather than new hardware deployments, and they address Gaps 1, 2, and 4 identified in the post-incident assessment: exposed attack surface, absent multi-factor authentication, and cleartext credential transmission, respectively. The nine previously WAN-accessible management portals have been confirmed closed as of April 10, 2026.

The spray detection script deployed on the domain controller provides a new automated detection function that did not exist before the project, addressing Gap 5. RCHS-IS-004 provides the governance layer that ties the technical controls together, defining what events are reviewed, how often reviews are conducted, who is responsible for each review tier, and what constitutes an anomaly requiring escalation. Together, these technical and procedural elements transform the RCHS security environment from one that was entirely dependent on external MDR alerting, alerting that demonstrably failed to detect a six-month sustained attack, to one that maintains independent, internally controlled detection and audit capabilities complementing the continued MDR service; however, the long-term effectiveness of this independent capability will depend on sustained organizational commitment to the review cadences and threshold tuning procedures that give the technical infrastructure its operational meaning.

The figure in Screenshot [24] Post Remediation Mermaid Auth Diagram illustrates the post-implementation architecture, showing the WEC collector virtual machine connected to the domain controller via Windows Event Forwarding, the SonicWall SSL VPN with all five security gates configured (IP allowlist, per-user TOTP enrollment, Active Directory security group enforcement, TOTP multi-factor authentication, and LDAPS), the DFSR file servers with SACL-enabled PHI audit logging, and the WEF forwarding paths from both the domain controller and file servers to the centralized WEC collector (see Screenshot [24], Appendix O, Post-Remediation Authentication Architecture Diagram).

F1. Security Posture and Efficiency

The solution's impact on organizational security posture is assessed through a systematic before-and-after comparison across all six systemic gaps identified during and after the February 2026 incident. The full comparison table and detailed gap-by-gap analysis appear in Appendix I; the summary presented here synthesizes the key findings and current status for each gap.

Gap 1, the exposed attack surface consisting of nine WAN-accessible SonicWall management portals, has been fully closed. All nine interfaces, at IP addresses 72.91.34.152, 72.91.34.71, 74.62.88.201, 67.184.93.215, 25.114.142.8, 25.114.198.4, 74.29.31.53, 74.29.33.18, and 74.62.88.51, returned `ERR_CONNECTION_TIMED_OUT` when accessed from an external cellular connection on April 10, 2026, as documented in Screenshots [04a] through [04i] (see Appendix O). Gap 2, the absence of multi-factor authentication on the SSL VPN portal, has been fully closed through TOTP MFA enforcement on the SSLVPN Services group; one hundred percent of whitelisted-IP VPN connection attempts without a valid TOTP code are rejected, as validated through the Gate 4 test procedure documented in Appendix G and the per-user enrollment confirmation chain established by RCHS-TRAIN-002.

Gap 3, the absence of centralized log collection and routine review, has been closed through the deployment of the WEF/WEC infrastructure and the creation of RCHS-IS-004. The Forwarded Events log accumulated 2,571 events from the domain controller during the testing period, and the policy establishes the review cadence and accountability structure necessary to convert collected data into reviewed, actionable security intelligence; RCHS-IS-004 is content-complete and pending executive and compliance officer signatures, which represents an administrative step with no technical dependency on the deployed infrastructure. Gap 4, the cleartext LDAP credential transmission on port 389, has been fully closed through the LDAPS migration to port 636. Wireshark validation on April 6, 2026 confirmed zero packets on port 389 using the capture filter `host 10.1.3.1 and tcp port 389`, and confirmed active TLS 1.2/1.3 handshake on port 636 with 80 packets captured and 24 displayed; the TLS capture included a Fatal: Unknown CA alert, which represents expected behavior for a self-signed domain controller certificate not fully trusted by the SonicWall appliance and confirms that TLS negotiation is occurring rather than indicating a failure condition (see Appendix O, Phase 3 Screenshots).

Gap 5, the absence of automated spray detection, has been closed through the deployment of the dual-threshold PowerShell detection script. Before the project, the 140-to-160-times-above-baseline authentication failure spike generated by the February 2026 attack went undetected for approximately six months because no automated mechanism existed to surface the anomaly. The April 11, 2026 controlled simulation confirmed that both detection thresholds fired against real authentication event data: the account threshold was exceeded when `spray_test01` accumulated 26 failures against the 11-consecutive-failure threshold at 16:56:53, and the spray pattern threshold was exceeded when all five distinct test accounts (`spray_test01` through `spray_test05`) recorded failures within the one-hour detection window, as documented in Screenshot [23] (see Appendix O, Phase 4 Screenshots). Gap 6, the MDR provider detection threshold not calibrated for the RCHS environment, remains partially addressed. The formal SLA review conducted on March 18, 2026 with Desert Cat Concierge Manager Ethan Calloway confirmed that the threshold limitation is a platform-level constraint rather than a per-customer configuration; per-customer tuning has been committed to the product roadmap, although it is not difficult to identify that Desert Cat, as the provider whose platform failed to detect a six-month sustained attack, has a considerable interest in framing this limitation as a solvable

roadmap item rather than a structural deficiency. The critical user list has been corrected to include RCHS_Architect and rtorres. The WEF/WEC infrastructure and the spray detection script serve as compensating controls, providing RCHS-internal detection capability independent of MDR alerting thresholds (see Appendix I for the full comparison and Appendix N for the SLA review record).

Operational efficiency has improved substantially across the security monitoring function. Before the project, security event review required manual Wireshark packet capture analysis on the domain controller, a specialized skill requiring hours of sustained effort, performed only under crisis conditions. The post-implementation environment provides centralized event access through Event Viewer on the WEC collector, a scheduled review procedure defined in RCHS-IS-004 with weekly, monthly, quarterly, and annual review tiers, and a spray detection script that surfaces threshold alerts without requiring the operator to interpret raw event log entries manually. Security review has been transformed from an exceptional, crisis-triggered activity requiring specialized protocol analysis expertise into a routine operational function that any qualified IT staff member can perform by following the documented eight-step review procedure. Whether this operational efficiency is sustained over time will depend on the organization's commitment to the review cadence and threshold tuning cycles established in RCHS-IS-004; the infrastructure provides the capability, but the governance framework must be actively maintained to preserve its value.

F2. New Data Analysis

The solution introduces three categories of security data that were not collected before the project, each of which directly addresses a gap in the organization's ability to detect, investigate, and respond to security events. The WEC Forwarded Events log is the new central data source. As of April 11, 2026, the testing period had accumulated 2,571 events from the domain controller via the RCHS-SecurityEvents subscription.

Authentication events, including Event IDs 4624, 4625, 4740, 4648, and 4776, are now continuously forwarded to the WEC collector and available for both scheduled review and on-demand investigation. Screenshot [07] confirms the RCHS-SecurityEvents subscription is Active with one source computer enrolled, and Screenshot [09] shows the Forwarded Events log populated with Event ID 4624 entries, with the Computer column confirming the source as WIN-KE7QK2G934F.homelab.local and the detail pane displaying event metadata including timestamp, account name, and logon type (see Appendix O, Phase 2 Screenshots). This data enables continuous monitoring of authentication patterns against the thresholds defined in RCHS-IS-004 and provides the event foundation for the automated spray detection capability.

PHI file access events generated by the SACL configuration on PHI-bearing file shares constitute the second new data category. Screenshot [10] documents the SACL configuration on the C:\PHI_TestShare directory, and Screenshot [11] confirms that Event ID 4663 arrived in the Forwarded Events log at 4:00:16 PM, sixteen seconds after the file operation, demonstrating end-to-end pipeline latency well within the five-minute KPI threshold (see Appendix O, Phase 2 Screenshots). The spray simulation conducted on April 11, 2026, generated a third data category consisting of controlled attack data that validated the detection pipeline end-to-end: Screenshot [22] shows Event IDs 4776 and 4625 in the Forwarded Events log during the simulation period, with Logon Account spray_test01, Error Code 0xC000006A, Audit Failure status, and Computer WIN-KE7QK2G934F.homelab.local; Screenshot [23] shows the detection script output reporting

50 total failed authentication events across 5 distinct accounts, with both the account threshold and the spray pattern threshold at ALERT status (see Appendix O, Phase 4 Screenshots).

The business process impact of this new data collection is substantial. Before the project, security event review was ad hoc, investigator-dependent, and reliant on Wireshark packet capture, a specialized tool that required protocol-level expertise to operate and interpret. The post-implementation model enables any qualified IT staff member to open Event Viewer on the WEC collector and follow the RCHS-IS-004 eight-step review procedure without requiring specialized packet analysis skills. The spray detection script can be executed on schedule or on demand, and its output reports threshold status directly, without requiring the operator to interpret raw event log entries, fundamentally reducing the skill barrier to security event monitoring. It remains to be seen whether the event volumes and detection thresholds established during this initial implementation will require adjustment as the organization's operational patterns stabilize. Still, the infrastructure now exists to support evidence-based tuning rather than speculative configuration.

For compliance purposes, HIPAA audit control requirements under §164.312(b) are now met by a running system with defined review procedures and a six-year retention schedule, rather than an aspirational control that existed only in organizational intent, without supporting technical infrastructure (U.S. Department of Health and Human Services, 2003). Future HIPAA audits or breach investigations can draw on a structured event archive rather than relying on forensic reconstruction from ad hoc packet captures. For clinical operations, the solution imposes no burden on clinical or administrative staff; SACL events are generated silently without affecting PHI file access behavior or care delivery workflows, and the only user-facing change is the TOTP prompt at VPN connection for the ten VPN users, a one-time enrollment process with low ongoing friction during daily use. Non-VPN staff experience no operational impact from any component of the implemented solution. The significance of this low-friction integration model extends beyond the immediate project; it demonstrates that meaningful security improvements can be achieved at small healthcare organizations without the budget, staffing, or operational disruption typically associated with enterprise-scale security deployments.

F3. Summative Evaluation

The summative evaluation plan established in Task 2, Section H, defined two components: H1, specifying management authorization requirements including written approval before execution, restriction to non-production test accounts, and defined scope boundaries; and H2, defining pass/fail acceptance criteria for each of the seven key performance indicators corresponding to the systemic gaps identified during and after the February 2026 incident. Management authorization was obtained in writing from Executive Director Daniel Mercer before the controlled spray simulation, as documented in Appendix L. The simulation was conducted on April 11, 2026, using five non-production test accounts (spray_test01 through spray_test05), created at 16:12:54 and disabled at 17:01:04 to minimize residual risk. The full summative evaluation record appears in Appendix K.

Table 1 presents the results for all seven key performance indicators defined in the Task 2 acceptance criteria. Each criterion corresponds to a systemic security gap or control requirement identified during and after the February 2026 incident.

KPI	Acceptance Criterion	Result	Evidence
MFA Enforcement	100% of whitelisted-IP VPN attempts without a valid TOTP are rejected	PASS*	Screenshot [01]; Appendix G Gate 4 PASS; RCHS-TRAIN-002 per-user enrollment
Management Interface Closure	0 of 9 interfaces accessible from WAN	PASS	Screenshots [04a]–[04i]: ERR_CONNECTION_TIMED_OUT, April 10, 2026
WEF/WEC Event Forwarding	Event IDs 4625/4740/4663 forwarded to WEC within a 5-minute window	PASS	Screenshot [07] (Active); [11] (16-second latency); [09] (2,571 events)
LDAPS Migration	Zero cleartext LDAP bind requests on port 389 during a 30-minute window	PASS	Wireshark [145055]: No Packets port 389; [142646]: TLS 1.2/1.3 on port 636
Spray Detection, Account Threshold	Alert after 11th consecutive failure on a single account	PASS	Screenshot [23]: spray_test01, 26 failures; ACCOUNT THRESHOLD EXCEEDED
Spray Detection, Spray Pattern	Alert after 5th distinct account failure within a 1-hour window	PASS	Screenshot [23]: 5 distinct accounts; SPRAY PATTERN DETECTED
HIPAA Audit Control Compliance	Log Review and Incident Detection Policy signed and in effect	IN PROGRESS	RCHS-IS-004 finalized; signatures pending administrative scheduling

Five of seven criteria received a full PASS verdict based on direct, contemporaneous evidence. The MFA Enforcement criterion is assessed as PASS with an evidentiary qualification, noted as PASS* in Table 1. TOTP-based two-factor authentication was configured on the SonicWall SSLVPN Services group as documented in Appendix G, Gate 4, with a recorded PASS result from the April 7, 2026, field session conducted by Marcus Hale. The IP allowlist is confirmed active in the live firewall access rule policy through evidence items [03a] and [03b], which show the SSLVPN IP Whitelist rule applied to inbound SSL VPN traffic. All ten members of the RCHS-VPN-Users group, Marcus.hale, rtorres, dholton, Patricia.Denny, Miranda.mcallister, McCallister, Jessica.crane, mburns, jkeene, cleblanc, and tmorgan completed TOTP enrollment and confirmed successful test logins as a prerequisite to restoring VPN access, as documented in RCHS-TRAIN-002. The evidentiary limitation is that a screenshot demonstrating a live blocked authentication attempt from a non-whitelisted IP, or a rejected attempt from an allowed IP without a valid TOTP code, is unavailable because access to the live SonicWall management environment ended before this specific test could be captured. Screenshot [01] shows the SonicWall SSLVPN Services group Add Group Settings dialog with the One-time Password Method dropdown visible, providing visual context for the configuration interface used during the TOTP setup. The Appendix G Gate 4 test record, the April 7 field session logs, and the RCHS-TRAIN-002 per-user enrollment confirmation together constitute sufficient documentation that the criterion is met.

The HIPAA Audit Control Compliance criterion is assessed as IN PROGRESS, pending administrative signature on RCHS-IS-004. The policy content satisfies all substantive KPI requirements: Marcus Hale is designated as policy owner with defined accountability; the review schedule defines weekly, monthly, quarterly, and annual review cycles with specific scope and

responsible parties; the six-year retention period complies with 45 C.F.R. §164.316(b)(2); and the regulatory basis section cites HIPAA §164.312(b), NIST SP 800-53 Rev. 5 AU controls, and CIS Controls v8 Control 8. The single item preventing a full PASS verdict is the absence of the Executive Director's and Compliance Officer's physical signatures on the policy signature page. The corrective action is to schedule a signature session with both co-signatories within 30 days of project close. This action has no technical dependencies and can proceed independently of all other project activities. Upon completion of the signature step, this criterion upgrades to a full PASS.

The MDR coverage gap (Gap 6) is the only systemic gap that could not be fully closed by the project, as the platform-level threshold constraint at Desert Cat is beyond the organization's or provider's unilateral control. The formal SLA review completed on March 18, 2026, resulted in the critical user list being corrected and per-customer threshold tuning being committed to the product roadmap with a proactive notification commitment. The WEF/WEC infrastructure and the spray detection script are treated as compensating controls, providing RCHS-internal detection capability independent of MDR alerting thresholds. Quarterly MDR SLA reviews per RCHS-IS-004 will track the roadmap commitment and maintain formal organizational pressure for resolution. However, it is still too early to determine whether Desert Cat's commitment will translate into a technically meaningful improvement in detection sensitivity for organizations of RCHS's size (see Appendix K for the full summative evaluation record).

F4. Post-Implementation Risks

Eight residual risks have been identified in the post-implementation environment, each assessed for likelihood and organizational impact and accepted at residual levels following the implementation of corresponding mitigation strategies. No risk exceeds a combined Medium likelihood and impact rating. The full risk register, with quantified ratings, detailed mitigation narratives, and risk ownership assignments, appears in Appendix J; the summary presented here describes each risk substantively and identifies the corresponding mitigation approach.

The two risks associated with the LDAPS migration address certificate lifecycle management and configuration reversion. LDAPS certificate expiration (R-01, Medium likelihood, High impact) represents the most significant single residual risk in the post-implementation environment. If the domain controller certificate expires unnoticed, LDAPS authentication fails, and VPN access breaks organization-wide, as all VPN authentication flows through the LDAPS-secured connection between the SonicWall appliance and the domain controller. Mitigation consists of incorporating certificate expiration date monitoring into the monthly RCHS-IS-004 review cycle to provide recurring visibility into the certificate's remaining validity period. Cleartext LDAP configuration reversion (R-02, Low likelihood, High impact) could occur if a future SonicWall firmware update or administrator misconfiguration reverts the LDAP port setting from 636 to 389, silently restoring the cleartext credential exposure; mitigation includes Wireshark validation of LDAPS during the quarterly review cycle and the documented Gate 5 verification procedure in Appendix G.

Three risks address ongoing operational considerations within the post-implementation environment. IP allowlist operational overhead (R-03, Medium likelihood, Medium impact) arises because dynamic ISP IP address changes require VPN users to notify IT and request allowlist updates, creating recurring administrative ticket volume and lockout risk when a user's WAN IP changes without prior notification; the allowlist update procedure is documented in Appendix G, and RCHS-TRAIN-002 includes WAN IP identification instructions for each VPN

user to enable self-service notification. WEC single point of failure (R-04, Low-Medium likelihood, Medium impact) reflects the architectural reality that if the WEC collector virtual machine goes offline, event forwarding ceases without immediate operational impact to clinical or administrative functions, making the failure invisible to daily operations; periodic subscription health checks through the Event Viewer Subscriptions pane per the RCHS-IS-004 monthly review cadence provide the detection mechanism. Spray detection alert fatigue (R-05, Medium likelihood, Medium impact) acknowledges that the detection thresholds may generate false positives from legitimate repeated password mistyping by staff, and that sustained false positive volume could reduce the fidelity of response over time; the Level 1 and Level 2 triage procedure in RCHS-IS-004 provides structured response guidance, and quarterly threshold review enables sensitivity tuning based on observed operational data.

The remaining three risks address external dependencies and long-term behavioral factors. The MDR coverage gap persisting beyond the roadmap commitment (R-06, Medium likelihood, Low-Medium impact) reflects the possibility that per-customer threshold tuning may not materialize within the committed timeframe; this risk is mitigated by treating the WEF/WEC infrastructure and spray detection script as primary internal controls rather than supplements to MDR alerting for credential spray detection specifically. Training behavioral compliance degradation (R-07, Medium likelihood, Low-Medium impact) acknowledges that staff security awareness behaviors may degrade over time without reinforcement; annual training renewal per RCHS-IS-004 and signed acknowledgment forms provide the accountability mechanism. SACL event volume on production DFSR file servers (R-08, Low likelihood, Low impact) recognizes that production-scale PHI file access may generate Forwarded Events volume exceeding what was observed during the testing period; subscription filter tuning and volume assessment during the first quarterly review provide the initial monitoring approach. All eight risks are accepted at their residual levels, and the full risk register in Appendix J provides the quantified assessment and detailed mitigation narrative for each. The quarterly review cadence established in RCHS-IS-004 provides the mechanism for reassessing these risk ratings as operational data accumulates and as external factors, including the MDR provider's roadmap progress and the organization's staffing trajectory, evolve.

F5. Meeting Stakeholder Needs

The security solution addresses the documented needs of seven stakeholder groups identified in Task 2, each of which was shaped by the February 2026 incident and the systemic vulnerabilities it exposed. IT administration and security staff, represented by Marcus Hale and the RCHS IT team, required security visibility, documented procedures, and reduced knowledge concentration. The WEF/WEC infrastructure provides centralized event access without dependency on MDR log exports or Wireshark packet captures; Appendix G formalizes VPN security procedures as repeatable, numbered steps with PASS/FAIL validation; and RCHS-IS-004 defines a log review process that any qualified staff member can execute without specialized protocol analysis skills. The field session logs from April 1 and April 7, 2026, document the live implementation activities that deployed these capabilities.

Executive leadership, represented by Executive Director Daniel Mercer, required governance documentation, formalization of the security function, and risk visibility. The written spray simulation authorization documented in Appendix L demonstrates direct executive engagement in security testing decisions. RCHS-IS-004 designates formal security function ownership and accountability to the IT Systems Administrator, with co-authorization by

executive and compliance leadership, ensuring that the security function carries organizational authority. The summative evaluation documented in Appendix K provides evidence-based security posture reporting that enables executive oversight of the remediation outcomes and residual risk acceptance.

The clinical and administrative workforce of approximately 80 staff members required security awareness training without disrupting care delivery. All-staff security awareness training delivered on April 7, 2026 (RCHS-TRAIN-001, Appendix M) addressed threat recognition and reporting requirements. The VPN configuration changes had no impact on non-VPN staff. For the 10 VPN users, the TOTP enrollment training (RCHS-TRAIN-002) was completed, with access restored only upon confirmed enrollment, ensuring no user experienced an unplanned access disruption. The SACL configuration generates file access events silently without affecting clinical file access workflows or requiring any change in staff behavior.

The Compliance Officer and Privacy Officer required HIPAA §164.312 technical safeguard compliance documentation and a structured audit trail. RCHS-IS-004 directly addresses §164.312(b) audit controls; the LDAPS migration addresses §164.312(e)(1) transmission security; MFA and the IP allowlist address §164.312(d) person authentication and §164.312(a)(1) access control; and the training records in Appendix M satisfy §164.308(a)(5) security awareness requirements. The summative evaluation in Appendix K provides a structured compliance pass/fail record organized by control area.

The MDR provider, Desert Cat, required accurate critical account visibility and a formal feedback channel for the detection gap. The formal written gap inquiry conducted during Task 2 (Appendix B) led to the March 18, 2026, SLA review documented in Appendix N, during which Concierge Manager Ethan Calloway confirmed the threshold limitation, corrected the critical user list to include RCHS_Architect and rtorres, and committed per-customer threshold tuning to the product roadmap with a proactive notification agreement. The relationship between RCHS and Desert Cat was strengthened through this formal engagement rather than diminished by the detection gap. However, it bears noting that a provider whose core service failed to detect sustained attack activity for six months has a natural interest in demonstrating responsiveness to client concerns to retain the service contract.

Patients, as ePHI data subjects, require technical safeguards to protect their health information from unauthorized access, regardless of the organization's size or resource constraints. The LDAPS migration encrypts authentication credentials in transit; TOTP MFA prevents credential-only VPN access to the network segment where ePHI is stored and processed; SACL provides PHI file access detection capability; and the IP allowlist reduces the external attack surface available to threat actors. These controls collectively address the conditions that allowed the February 2026 attack to persist undetected for approximately six months on the network infrastructure hosting electronic protected health information.

The HHS Office for Civil Rights, as the federal entity responsible for HIPAA enforcement, requires covered entities to provide evidence of gap identification and compliant remediation. The documentation package produced by this project, including RCHS-IS-004, the training records, the summative evaluation, and the before-and-after security posture comparison in Appendix I, demonstrates a structured, evidence-based response to identified §164.312 gaps that extends beyond immediate incident containment to address the systemic conditions that enabled the incident. The project demonstrates proactive compliance improvement, with each control mapped to a specific HIPAA provision and validated through defined acceptance criteria. Whether this documentation proves sufficient in a future enforcement context will depend on the

organization's continued adherence to the review cadences and retention schedules established during the project. Still, the evidentiary foundation for demonstrating good-faith compliance has been substantively established.

G. Post-Implementation Maintenance Plan

The post-implementation maintenance plan establishes a structured schedule for ongoing monitoring, review, and maintenance of all deployed controls, derived from RCHS-IS-004 Section 6 and the maintenance sections of Appendix G. The plan is organized into four tiers corresponding to weekly, monthly, quarterly, and annual review cycles, with an additional incident-triggered escalation procedure for events detected outside scheduled review periods.

Weekly maintenance consists of Marcus Hale reviewing the Forwarded Events log on the WEC collector for elevated Event ID 4625 (failed logon) and Event ID 4740 (account lockout) volumes above established baseline levels. The spray detection script is executed on demand or on a scheduled basis during the weekly review, with output reviewed for threshold crossings that would trigger the Level 1 escalation procedure defined in RCHS-IS-004. This weekly cadence provides the most frequent monitoring touchpoint and is calibrated to detect the type of sustained authentication anomaly that characterized the February 2026 attack.

Monthly maintenance expands the review scope to encompass a full Forwarded Events review across all event categories defined in the RCHS-IS-004 event table, including both authentication events and PHI file access events generated by the SACL configuration. The WEC subscription health check verifies, via the Event Viewer Subscriptions pane, that all enrolled forwarders report Active status with zero Error conditions, ensuring the event forwarding pipeline remains operational. The LDAPS certificate expiration date is checked against the domain controller certificate to ensure adequate lead time for renewal before expiration. PHI file access patterns are reviewed for anomalies, including unusual access volume, access from unexpected accounts, or access patterns inconsistent with normal clinical and administrative operations.

Quarterly maintenance includes a policy effectiveness review to assess whether the detection thresholds and review procedures in RCHS-IS-004 remain appropriate based on observed operational data, including false-positive rates and alert volumes. The MDR SLA review with Desert Cat follows up on the per-customer threshold tuning roadmap commitment discussed during the March 18, 2026, meeting with Ethan Calloway and evaluates whether the compensating control model for Gap 6 remains necessary or whether provider-side improvements have reduced its criticality. The IP allowlist is audited to confirm that all listed WAN addresses remain associated with active VPN users and that departed staff have been removed from both the allowlist and the RCHS-VPN-Users Active Directory group. Spray detection thresholds are reviewed and tuned based on the operational data accumulated since the previous quarterly review.

Annual maintenance consists of RCHS-IS-004 policy review and re-authorization, requiring approval by Marcus Hale, the Executive Director, and the Compliance Officer to confirm continued applicability and update any provisions affected by infrastructure or organizational changes. All-staff security awareness training is renewed through a new RCHS-TRAIN-001 session that reinforces threat recognition and reporting behaviors. The LDAPS certificate is renewed when it approaches its expiration window. The Appendix G VPN Secure Setup Runbook is reviewed and updated to reflect any SonicWall firmware upgrades, configuration changes, or VPN user roster modifications that occurred during the year.

If spray detection thresholds fire outside a scheduled review cycle, the RCHS-IS-004 Level 1 and Level 2 escalation procedures define the incident response path. Level 1 investigation, executed by Marcus Hale as policy owner, involves assessing the source account to

determine whether the threshold crossing indicates a legitimate operational event, such as repeated password mistyping, or a potential attack indicator. Level 2 escalation, triggered when Level 1 investigation confirms potential attack indicators, engages the Executive Director and Compliance Officer and includes formal notification to Desert Cat, activating the coordinated incident response process defined in the MDR service agreement and ensuring that both internal and external detection resources are applied to the event. The maintenance plan's tiered structure is designed to sustain the security improvements achieved during the project while providing the flexibility to adapt review procedures, detection thresholds, and escalation paths as organizational conditions, threat intelligence, and regulatory expectations evolve over the coming years.

H. Original Artifact

The original artifact submitted with this project is the RCHS Log Review and Incident Detection Policy, designated RCHS-IS-004, created in April 2026 as a direct output of the cybersecurity remediation effort. No pre-existing RCHS policy governing centralized log review, incident detection thresholds, anomaly escalation procedures, or security event audit management existed before this project; RCHS-IS-004 is an entirely original document developed to address the governance gap that the February 2026 credential spray incident exposed when six months of sustained attack activity generated no internal alert, no external MDR notification, and no documented review of the security events accumulating on the domain controller.

RCHS-IS-004 is the governance artifact that transforms the WEF/WEC (Windows Event Forwarding/Windows Event Collector) technical infrastructure into a sustained compliance program. The infrastructure collects data; the policy defines what to do with that data, how frequently it is reviewed, who is responsible for each review tier, and what constitutes an anomaly requiring investigation and escalation. Without this policy, the WEC collector would accumulate events with no defined process for converting that data into actionable security intelligence, and the centralized logging investment would function as a passive archive rather than an active detection and compliance mechanism. The policy includes eight anomaly thresholds with tiered escalation procedures, a four-tier review schedule covering weekly, monthly, quarterly, and annual cycles, formal role assignments designating Marcus Hale as Policy Owner with executive and compliance co-authorization, and a six-year log retention schedule aligned with HIPAA documentation requirements under 45 C.F.R. §164.316(b)(2).

RCHS-IS-004 directly addresses HIPAA § 164.312(b), the audit control requirement that was absent at the time of the February 2026 attack and constituted a documented compliance gap for the organization (U.S. Department of Health and Human Services, 2003). The policy's regulatory basis also encompasses NIST SP 800-53 Rev. 5 controls AU-2, AU-3, AU-6, AU-9, AU-11, and SI-4, and CIS Controls v8 Control 8, ensuring that the governance framework is aligned with multiple industry-standard compliance references beyond the HIPAA requirements alone (National Institute of Standards and Technology, 2020; Center for Internet Security, 2021). The policy content is finalized and pending executive and compliance officer signatures, an administrative step with no technical dependency. The full text of RCHS-IS-004 appears in Appendix H of the supporting documentation. As the threat landscape facing small healthcare organizations continues to intensify and federal enforcement of the HIPAA Security Rule becomes increasingly granular, the governance framework established by RCHS-IS-004 positions RCHS to meet future compliance expectations from a foundation of documented, validated, and operationally sustained security controls rather than from the reactive posture that characterized the pre-incident environment.

I. Sources

- Center for Internet Security. (2021). CIS Controls version 8. Center for Internet Security.
<https://www.cisecurity.org/controls/v8>
- Cybersecurity and Infrastructure Security Agency. (2020). Understanding and mitigating credential-based attacks on U.S. critical infrastructure. CISA.
<https://www.cisa.gov/news-events/cybersecurity-advisories>
- Desert Cat. (2026). Written communications regarding detection threshold scope, critical user list correction, and per-customer tuning roadmap commitment [Internal MDR provider correspondence, February–March 2026].
- Microsoft Security. (2021). Protecting against password spray attacks. Microsoft.
<https://www.microsoft.com/en-us/security/blog/2021/10/26/protecting-against-password-spray-attacks/>
- National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Revision 5). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.SP.800-53r5>
- National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.CSWP.29>
- Nelson, P., Grance, T., & Mell, P. (2025). Computer security incident handling guide (NIST Special Publication 800-61, Revision 3). National Institute of Standards and Technology.
<https://doi.org/10.6028/NIST.SP.800-61r3>
- U.S. Department of Health and Human Services. (2003). Health Insurance Portability and Accountability Act of 1996: Security standards for the protection of electronic protected health information; final rule (45 C.F.R. Parts 160, 162, and 164). Federal Register, 68(34), 8334–8381.
- Verizon. (2024). 2024 Data Breach Investigations Report. Verizon Enterprise Solutions.
<https://www.verizon.com/business/resources/reports/dbir/>